

Escenario Ficticio Eng

Botium Toys: Scope, goals, and risk assessment report

Scope and goals of the audit

Scope: The scope of this audit is defined as the entire security program at Botium Toys. This includes their assets like employee equipment and devices, their internal network, and their systems. You will need to review the assets Botium Toys has and the controls and compliance practices they have in place.

Goals: Assess existing assets and complete the controls and compliance checklist to determine which controls and compliance best practices that need to be implemented to improve Botium Toys' security posture.

Current assets

Assets managed by the IT Department include:

- On-premises equipment for in-office business needs
- Employee equipment: end-user devices (desktops/laptops, smartphones), remote workstations, headsets, cables, keyboards, mice, docking stations, surveillance cameras, etc.
- Storefront products available for retail sale on site and online; stored in the company's adjoining warehouse
- Management of systems, software, and services: accounting, telecommunication, database, security, ecommerce, and inventory management
- Internet access
- Internal network
- Data retention and storage
- Legacy system maintenance: end-of-life systems that require human monitoring

Risk assessment

Risk description

Currently, there is inadequate management of assets. Additionally, Botium Toys does not have all of the proper controls in place and may not be fully compliant with U.S. and international regulations and standards.

Control best practices

The first of the five functions of the NIST CSF is Identify. Botium Toys will need to dedicate resources to identify assets so they can appropriately manage them. Additionally, they will need to classify existing assets and determine the impact of the loss of existing assets, including systems, on business continuity.

Risk score

On a scale of 1 to 10, the risk score is 8, which is fairly high. This is due to a lack of controls and adherence to compliance best practices.

Additional comments

The potential impact from the loss of an asset is rated as medium, because the IT department does not know which assets would be at risk. The risk to assets or fines from governing bodies is high because Botium Toys does not have all of the necessary controls in place and is not fully adhering to best practices related to compliance regulations that keep critical data private/secure. Review the following bullet points for specific details:

- Currently, all Botium Toys employees have access to internally stored data and may be able to access cardholder data and customers' PII/SPII.
- Encryption is not currently used to ensure confidentiality of customers' credit card information that is accepted, processed, transmitted, and stored locally in the company's internal database.
- Access controls pertaining to least privilege and separation of duties have not been implemented.
- The IT department has ensured availability and integrated controls to ensure data integrity.
- The IT department has a firewall that blocks traffic based on an appropriately defined set of security rules.
- Antivirus software is installed and monitored regularly by the IT department.

- The IT department has not installed an intrusion detection system (IDS).
- There are no disaster recovery plans currently in place, and the company does not have backups of critical data.
- The IT department has established a plan to notify E.U. customers within 72 hours if there is a security breach. Additionally, privacy policies, procedures, and processes have been developed and are enforced among IT department members/other employees, to properly document and maintain data.
- Although a password policy exists, its requirements are nominal and not in line with current minimum password complexity requirements (e.g., at least eight characters, a combination of letters and at least one number; special characters).
- There is no centralized password management system that enforces the password policy's minimum requirements, which sometimes affects productivity when employees/vendors submit a ticket to the IT department to recover or reset a password.
- While legacy systems are monitored and maintained, there is no regular schedule in place for these tasks and intervention methods are unclear.
- The store's physical location, which includes Botium Toys' main offices, store front, and warehouse of products, has sufficient locks, up-to-date closed-circuit television (CCTV) surveillance, as well as functioning fire detection and prevention systems.

Escenario Ficticio Spa

Botium Toys: Alcance, objetivos e informe de evaluación de riesgos

Alcance y objetivos de la auditoría

- **Alcance:** El alcance de esta auditoría se define como la totalidad del programa de seguridad en Botium Toys. Esto incluye sus activos, como los equipos y dispositivos de los empleados, su red interna y sus sistemas. Deberá revisar los activos que posee Botium Toys, así como los controles y las prácticas de cumplimiento que tienen implementados.
- **Objetivos:** Evaluar los activos existentes y completar la lista de verificación de controles y cumplimiento para determinar qué controles y mejores prácticas regulatorias deben implementarse a fin de mejorar la postura de seguridad de Botium Toys.

Activos actuales Los activos administrados por el Departamento de TI incluyen:

- Equipos locales (*on-premises*) para las necesidades comerciales dentro de la oficina.
- Equipos de los empleados: dispositivos de usuario final (computadoras de escritorio/laptops, teléfonos inteligentes), estaciones de trabajo remotas, auriculares, cables, teclados, ratones, estaciones de acoplamiento (*docking stations*), cámaras de vigilancia, etc.
- Productos de la tienda disponibles para la venta minorista en el sitio y en línea; almacenados en el almacén contiguo de la empresa.
- Gestión de sistemas, software y servicios: contabilidad, telecomunicaciones, bases de datos, seguridad, comercio electrónico y gestión de inventario.
- Acceso a Internet.
- Red interna.
- Retención y almacenamiento de datos.
- Mantenimiento de sistemas heredados (*legacy*): sistemas al final de su vida útil (*end-of-life*) que requieren monitoreo humano.

Evaluación de riesgos

- **Descripción del riesgo:** Actualmente, existe una gestión inadecuada de los activos. Además, Botium Toys no tiene todos los controles adecuados implementados y es posible que no cumpla plenamente con las normativas y estándares estadounidenses e internacionales.
- **Mejores prácticas de control:** La primera de las cinco funciones del Marco de Ciberseguridad del NIST (NIST CSF) es Identificar (*Identify*). Botium Toys deberá dedicar recursos para identificar los activos de modo que puedan gestionarlos adecuadamente. Además, deberán clasificar los activos existentes y determinar el impacto que tendría la pérdida de dichos activos, incluyendo los sistemas, en la continuidad del negocio.

- **Puntuación de riesgo:** En una escala del 1 al 10, la puntuación de riesgo es 8, lo cual es bastante alto. Esto se debe a la falta de controles y a la falta de adhesión a las mejores prácticas de cumplimiento.
- **Comentarios adicionales:** El impacto potencial por la pérdida de un activo se califica como medio, ya que el departamento de TI no sabe qué activos estarían en riesgo. El riesgo para los activos o de multas por parte de los organismos reguladores es alto porque Botium Toys no tiene todos los controles necesarios implementados y no se adhiere completamente a las mejores prácticas relacionadas con las normativas de cumplimiento que mantienen los datos críticos privados y seguros. Revise los siguientes puntos para obtener detalles específicos:
 - Actualmente, todos los empleados de Botium Toys tienen acceso a datos almacenados internamente y podrían tener acceso a los datos de los titulares de tarjetas y a la Información de Identificación Personal (PII) / Información de Identificación Personal Sensible (SPII) de los clientes.
 - Actualmente no se utiliza cifrado para garantizar la confidencialidad de la información de las tarjetas de crédito de los clientes que se acepta, procesa, transmite y almacena localmente en la base de datos interna de la empresa.
 - No se han implementado controles de acceso relativos al principio de mínimo privilegio y a la separación de funciones (*segregation of duties*).
 - El departamento de TI ha garantizado la disponibilidad y ha integrado controles para asegurar la integridad de los datos.
 - El departamento de TI cuenta con un firewall que bloquea el tráfico basándose en un conjunto de reglas de seguridad adecuadamente definidas.
 - El software antivirus está instalado y es monitoreado regularmente por el departamento de TI.
 - El departamento de TI no ha instalado un sistema de detección de intrusos (IDS).
 - Actualmente no existen planes de recuperación ante desastres (*Disaster Recovery Plans*) implementados, y la empresa no cuenta con copias de seguridad (*backups*) de los datos críticos.
 - El departamento de TI ha establecido un plan para notificar a los clientes de la Unión Europea dentro de las 72 horas en caso de que se produzca una brecha de seguridad. Además, se han desarrollado políticas, procedimientos y procesos de privacidad que se aplican entre los miembros del departamento de TI y otros empleados, para documentar y mantener los datos adecuadamente.
 - Aunque existe una política de contraseñas, sus requisitos son nominales y no están en línea con los requisitos mínimos actuales de complejidad de contraseñas (por ejemplo, al menos ocho caracteres, una combinación de letras y al menos un número; caracteres especiales).
 - No existe un sistema centralizado de gestión de contraseñas que haga cumplir los requisitos mínimos de la política, lo que en ocasiones afecta la productividad cuando los empleados o proveedores envían un ticket al departamento de TI para recuperar o restablecer una contraseña.

- Si bien los sistemas heredados (*legacy*) se monitorean y mantienen, no existe un cronograma regular establecido para estas tareas y los métodos de intervención no están claros.
- La ubicación física de la tienda, que incluye las oficinas principales de Botium Toys, la fachada de la tienda y el almacén de productos, cuenta con cerraduras suficientes, vigilancia actualizada por televisión de circuito cerrado (CCTV), así como sistemas funcionales de detección y prevención de incendios.

Categorias de Control Eng

Control categories

Control categories

Controls within cybersecurity are grouped into three main categories:

- Administrative/Managerial controls
- Technical controls
- Physical controls

Administrative/Managerial controls address the human component of cybersecurity. These controls include policies and procedures that define how an organization manages data and clearly defines employee responsibilities, including their role in protecting the organization. While administrative controls are typically policy based, the enforcement of those policies may require the use of technical or physical controls.

Technical controls consist of solutions such as firewalls, intrusion detection systems (IDS), intrusion prevention systems (IPS), antivirus (AV) products, encryption, etc. Technical controls can be used in a number of ways to meet organizational goals and objectives.

Physical controls include door locks, cabinet locks, surveillance cameras, badge readers, etc. They are used to limit physical access to physical assets by unauthorized personnel.

Control types

Control types include, but are not limited to:

1. Preventative
2. Corrective
3. Detective
4. Deterrent

These controls work together to provide defense in depth and protect assets.

Preventative controls are designed to prevent an incident from occurring in the first

place. **Corrective controls** are used to restore an asset after an incident. **Detective controls** are implemented to determine whether an incident has occurred or is in progress. **Deterrent controls** are designed to discourage attacks.

Review the following charts for specific details about each type of control and its purpose.

Administrative Controls		
Control Name	Control Type	Control Purpose
Least Privilege	Preventative	Reduce risk and overall impact of malicious insider or compromised accounts
Disaster recovery plans	Corrective	Provide business continuity
Password policies	Preventative	Reduce likelihood of account compromise through brute force or dictionary attack techniques
Access control policies	Preventative	Bolster confidentiality and integrity by defining which groups can access or modify data
Account management policies	Preventative	Managing account lifecycle, reducing attack surface, and limiting overall impact from disgruntled former employees and default account usage
Separation of duties	Preventative	Reduce risk and overall impact of malicious insider or compromised accounts

Technical Controls		
Control Name	Control Type	Control Purpose
Firewall	Preventative	To filter unwanted or malicious traffic from entering the network
IDS/IPS	Detective	To detect and prevent anomalous traffic that matches a signature or rule
Encryption	Deterrent	Provide confidentiality to sensitive information
Backups	Corrective	Restore/recover from an event
Password management	Preventative	Reduce password fatigue
Antivirus (AV) software	Corrective	Detect and quarantine known threats
Manual monitoring, maintenance, and intervention	Preventative	Necessary to identify and manage threats, risks, or vulnerabilities to out-of-date systems

Physical Controls		
Control Name	Control Type	Control Purpose
Time-controlled safe	Deterrent	Reduce attack surface and overall impact from physical threats
Adequate lighting	Deterrent	Deter threats by limiting “hiding” places

Closed-circuit television (CCTV)	Preventative/Detective	Closed circuit television is both a preventative and detective control because it's presence can reduce risk of certain types of events from occurring, and can be used after an event to inform on event conditions
Locking cabinets (for network gear)	Preventative	Bolster integrity by preventing unauthorized personnel and other individuals from physically accessing or modifying network infrastructure gear
Signage indicating alarm service provider	Deterrent	Deter certain types of threats by making the likelihood of a successful attack seem low
Locks	Deterrent/Preventative	Bolster integrity by deterring and preventing unauthorized personnel, individuals from physically accessing assets
Fire detection and prevention (fire alarm, sprinkler system, etc.)	Detective/Preventative	Detect fire in physical location and prevent damage to physical assets such as inventory, servers, etc.

Categorias de Control Spa

Categorías de controles

Los controles dentro de la ciberseguridad se agrupan en tres categorías principales:

- Controles administrativos/gerenciales
- Controles técnicos
- Controles físicos

Los **controles administrativos/gerenciales** abordan el componente humano de la ciberseguridad. Estos controles incluyen políticas y procedimientos que definen cómo una organización gestiona los datos y establecen claramente las responsabilidades de los empleados, incluido su rol en la protección de la organización. Si bien los controles administrativos se basan generalmente en políticas, la aplicación de dichas políticas puede requerir el uso de controles técnicos o físicos.

Los **controles técnicos** consisten en soluciones como firewalls, sistemas de detección de intrusos (IDS), sistemas de prevención de intrusos (IPS), productos antivirus (AV), cifrado, etc. Los controles técnicos se pueden utilizar de diversas maneras para cumplir con las metas y objetivos de la organización.

Los **controles físicos** incluyen cerraduras de puertas, cerraduras de gabinetes, cámaras de vigilancia, lectores de credenciales, etc. Se utilizan para limitar el acceso físico a los activos físicos por parte de personal no autorizado.

Tipos de controles

Los tipos de controles incluyen, entre otros:

- Preventivos
- Correctivos
- Detectivos
- Disuasorios

Estos controles trabajan en conjunto para proporcionar una defensa en profundidad (*defense in depth*) y proteger los activos. Los controles **preventivos** están diseñados para evitar que ocurra un incidente en primer lugar. Los controles **correctivos** se utilizan para restaurar un activo después de un incidente. Los controles **detectivos** se implementan para determinar si un incidente ha ocurrido o está en curso. Los controles **disuasorios** están diseñados para desalentar los ataques.

Revise las siguientes tablas para obtener detalles específicos sobre cada tipo de control y su propósito.

Controles Administrativos

Nombre del control	Tipo de control	Propósito del control
Privilegio mínimo (<i>Least Privilege</i>)	Preventivo	Reducir el riesgo y el impacto general de amenazas internas maliciosas o cuentas comprometidas.
Planes de recuperación ante desastres	Correctivo	Proporcionar continuidad del negocio.
Políticas de contraseñas	Preventivo	Reducir la probabilidad de compromiso de cuentas mediante técnicas de ataque de fuerza bruta o de diccionario.
Políticas de control de acceso	Preventivo	Reforzar la confidencialidad y la integridad definiendo qué grupos pueden acceder a los datos o modificarlos.
Políticas de gestión de cuentas	Preventivo	Gestionar el ciclo de vida de las cuentas, reduciendo la superficie de ataque y limitando el impacto general de exempleados descontentos y el uso de cuentas predeterminadas.
Separación de funciones (<i>Separation of duties</i>)	Preventivo	Reducir el riesgo y el impacto general de amenazas internas maliciosas o cuentas comprometidas.

Controles Técnicos

Nombre del control	Tipo de control	Propósito del control
Firewall (<i>Cortafuegos</i>)	Preventivo	Filtrar el tráfico no deseado o malicioso para evitar que ingrese a la red.
IDS/IPS	Detectivo	Detectar y prevenir el tráfico anómalo que coincida con una firma o regla.
Cifrado (<i>Encryption</i>)	Disuasorio	Proporcionar confidencialidad a la información sensible.
Copias de seguridad (<i>Backups</i>)	Correctivo	Restaurar/recuperarse de un evento.
Gestión de contraseñas	Preventivo	Reducir la fatiga de contraseñas.
Software antivirus (AV)	Correctivo	Detectar y poner en cuarentena las amenazas conocidas.
Monitoreo, mantenimiento e intervención manual	Preventivo	Necesarios para identificar y gestionar amenazas, riesgos o vulnerabilidades en sistemas desactualizados.

Controles Físicos

Nombre del control	Tipo de control	Propósito del control
Caja fuerte con control de tiempo	Disuasorio	Reducir la superficie de ataque y el impacto general de las amenazas físicas.
Iluminación adecuada	Disuasorio	Disuadir amenazas limitando los lugares para "escondarse".
Televisión de circuito cerrado (CCTV)	Preventivo / Detectivo	Es un control tanto preventivo como detectivo porque su presencia puede reducir el riesgo de que ocurran ciertos tipos de eventos, y puede usarse después de un evento para informar sobre las condiciones del mismo.
Gabinetes con cerradura (para equipos de red)	Preventivo	Reforzar la integridad evitando que personal no autorizado y otros individuos accedan físicamente o modifiquen los equipos de la infraestructura de red.
Letreros que indican el proveedor de servicios de alarma	Disuasorio	Disuadir ciertos tipos de amenazas al hacer que la probabilidad de un ataque exitoso parezca baja.

Cerraduras	Disuasorio / Preventivo	Reforzar la integridad disuadiendo y previniendo que personal o individuos no autorizados accedan físicamente a los activos.
Detección y prevención de incendios (alarma, rociadores, etc.)	Detectivo / Preventivo	Detectar incendios en la ubicación física y prevenir daños a activos físicos como inventario, servidores, etc.

Auditoria Eng

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☐	☒	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance

- ☒ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)
-

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers’ credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers’ data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.

- | | | |
|-------------------------------------|--------------------------|---|
| ☒ | ☐ | Enforce privacy policies, procedures, and processes to properly document and maintain data. |
|-------------------------------------|--------------------------|---|

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☐	☒	Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

Auditoria Spa

Lista de verificación de controles y cumplimiento

Para completar la lista de verificación de evaluación de controles, consulte la información proporcionada en el informe de alcance, objetivos y evaluación de riesgos. Para obtener más detalles sobre cada control, incluyendo el tipo y propósito, consulte el documento de categorías de controles.

Luego, seleccione "Sí" o "No" para responder a la pregunta: ¿Botium Toys tiene actualmente implementado este control?

Lista de verificación de evaluación de controles

Sí	No	Control
	No	Privilegio mínimo (<i>Least Privilege</i>)
	No	Planes de recuperación ante desastres
	No	Políticas de contraseñas
	No	Separación de funciones (<i>Separation of duties</i>)
Si		Firewall (<i>Cortafuegos</i>)
	No	Sistema de detección de intrusos (IDS)
	No	Copias de seguridad (<i>Backups</i>)
Si		Software antivirus

	No	Monitoreo, mantenimiento e intervención manual para sistemas heredados (<i>legacy systems</i>)
	No	Cifrado (<i>Encryption</i>)
	No	Sistema de gestión de contraseñas
Si		Cerraduras (oficinas, tienda, almacén)
Si		Vigilancia por televisión de circuito cerrado (CCTV)
Si		Detección/prevenición de incendios (alarma contra incendios, sistema de rociadores, etc.)

Para completar la lista de verificación de cumplimiento, consulte la información proporcionada en el informe de alcance, objetivos y evaluación de riesgos. Para obtener más detalles sobre cada normativa de cumplimiento, revise la lectura sobre controles, marcos de trabajo (*frameworks*) y cumplimiento.

Luego, seleccione "Sí" o "No" para responder a la pregunta: ¿Botium Toys se adhiere actualmente a esta mejor práctica de cumplimiento?

Lista de verificación de cumplimiento

Estándar de Seguridad de Datos para la Industria de Tarjetas de Pago (PCI DSS)

Sí	No	Mejor práctica
	No	Solo los usuarios autorizados tienen acceso a la información de las tarjetas de crédito de los clientes.

	No	La información de las tarjetas de crédito se almacena, acepta, procesa y transmite internamente en un entorno seguro.
	No	Implementar procedimientos de cifrado de datos para proteger mejor los puntos de contacto y los datos de las transacciones con tarjetas de crédito.
	No	Adoptar políticas seguras de gestión de contraseñas.

Reglamento General de Protección de Datos (RGPD / GDPR)

Sí	No	Mejor práctica
	No	Los datos de los clientes de la U.E. se mantienen privados/seguros.
Si		Existe un plan implementado para notificar a los clientes de la U.E. dentro de las 72 horas si sus datos se ven comprometidos o si ocurre una brecha de seguridad.
	No	Asegurar que los datos estén clasificados e inventariados adecuadamente.
Si		Aplicar políticas, procedimientos y procesos de privacidad para documentar y mantener los datos adecuadamente.

Controles de Sistemas y Organizaciones (SOC tipo 1, SOC tipo 2)

Sí	No	Mejor práctica
	No	Se han establecido políticas de acceso de usuarios.
	No	Los datos sensibles (PII/SPII) son confidenciales/privados.
Si		La integridad de los datos asegura que la información sea consistente, completa, precisa y haya sido validada.
	No	Los datos están disponibles para los individuos autorizados a acceder a ellos.

Esta sección es opcional y se puede utilizar para proporcionar un resumen de recomendaciones al gerente de TI sobre qué controles y/o mejores prácticas de cumplimiento necesita implementar Botium Toys, basándose en el riesgo que supone no implementarlos de manera oportuna.

Recomendaciones (opcional): En esta sección, proporcione recomendaciones relacionadas con los controles y/o las necesidades de cumplimiento que su gerente de TI podría comunicar a las partes interesadas (*stakeholders*) para reducir los riesgos a los activos y mejorar la postura de seguridad de Botium Toys.

Comunicacion Eng

Security Audit Report

General Scope

The scope of this audit is defined as the comprehensive evaluation of the entire security program at Botium Toys. The objective is to review the organization's physical and logical security posture to assess existing controls, classify assets, and determine the level of adherence to compliance best practices.

1. Infrastructure and Physical Assets (In-Scope)

- **Employee equipment:** Devices managed by the IT department, including desktop computers, laptops, smartphones, remote workstations, and peripheral components.
- **Perimeter and physical security:** Main location facilities, which comprise the headquarters, storefront, and adjoining product warehouse. This includes the evaluation of locks, closed-circuit television (CCTV), and fire detection and prevention systems.

2. Networks and Technological Systems (In-Scope)

- **Network infrastructure:** Evaluation of the internal network, internet access, firewall rules, and data retention and storage methodologies.
- **Services and Applications:** Audit of accounting, telecommunications, database, security, e-commerce, and inventory management systems.
- **Legacy Systems:** Review of end-of-life systems and their manual monitoring and maintenance protocols.

3. Processes and Regulatory Compliance (In-Scope)

- **Security Controls:** Analysis of password policies, identity management, least privilege principles, separation of duties, antivirus software, disaster recovery plans, and backups.
- **Regulatory Frameworks:** Evaluation of compliance with PCI DSS standards (for credit card data protection), GDPR (for E.U. customer privacy), and the principles of SOC type 1 and 2 controls.

Out-of-Scope

- Security audits of external vendors, third-party cloud services, or external payment gateways not directly managed by Botium Toys.
- Social engineering testing (such as simulated phishing campaigns) directed at employees.

Detected Risks

1. **Deficient Authentication Policies (Weak Passwords):** Although a password policy exists, its requirements are nominal and do not mandate adequate minimum complexity (such as a combination of letters, numbers, and special characters). Furthermore, the

absence of a centralized password management system significantly increases the risk of unauthorized access through brute force attacks or credential theft.

2. **Absence of Access Controls and Segregation of Duties:** Currently, the principles of least privilege and separation of tasks are not enforced. This means that all employees have unrestricted access to internally stored data, including personal information (PII/SPII) and customer credit card data. This lack of technical boundaries eliminates internal traceability; in the event of a security breach or data theft, the IT team will be unable to conduct effective forensic analysis to determine the source of the leak or identify the compromised user.
3. **Lack of Encryption for Sensitive Data:** The company is not using encryption protocols to protect the confidentiality of customer financial information during its acceptance, processing, transmission, or local storage in the databases. This is a critical failure: if a malicious actor manages to bypass perimeter defenses and enter the system, they will be able to extract all data in plaintext at will. This not only guarantees the total exposure of the information but also ensures non-compliance with multiple international regulations (such as GDPR and PCI DSS).
4. **Absence of Backups and Recovery Plans (Critical Availability Risk):** The organization is extremely vulnerable to permanent data loss, ransomware attacks, or operational disruptions. By lacking backups of critical data or disaster response protocols, a major incident could completely paralyze or destroy the business.
5. **Absence of Intrusion Detection (Operational Blindness):** Although the perimeter network features a firewall, the company lacks tools to detect threats that manage to bypass this first barrier. Without an IDS, the company has no way of knowing if an attacker is already inside the network filtering data or moving laterally.
6. **Inadequate Management and Lack of Asset Inventory:** In cybersecurity, you cannot protect what you do not know. The IT department lacks a clear or classified system inventory, which precludes proper vulnerability management, impact assessment, and effective incident response.
7. **Vulnerabilities in Legacy Systems:** End-of-life systems represent a significant risk as they often lack modern security patches. At Botium Toys, the lack of clear procedures and regular schedules for the maintenance of these systems exponentially increases the probability of them being used as an entry vector by attackers.

Mitigation Urgency Plan

HIGH Priority (Critical and Immediate)

1. **(Risk 6) Inadequate Management and Asset Inventory:** Implement an exhaustive process to identify and classify all physical and logical assets of the company, aligning with the "Identify" function of the NIST CSF framework. This action is a fundamental step to determine which assets are at risk and to evaluate the impact on business continuity in the event of loss.
2. **(Risk 2) Access Controls and Segregation of Duties:** Immediately implement the principle of least privilege and separation of duties. Access to the internal network must be restricted so that only strictly authorized users can view and operate stored

information, thereby protecting cardholder data (PCI DSS) and customer PII/SPII (GDPR).

3. **(Risk 3) Encryption of Sensitive Data:** Deploy robust encryption protocols to ensure the confidentiality of customer financial information and other sensitive data. Encryption must be unavoidably applied at all points where information is accepted, processed, transmitted, and stored locally in the company's internal database.
4. **(Risk 4) Backups and Recovery Plans:** Develop, document, and test a Disaster Recovery Plan (DRP). Simultaneously, a system for regular and isolated backups of all critical business data must be immediately implemented, ensuring availability in the face of incidents.

MEDIUM Priority (Short-Term Implementation) 5. (Risk 1) Authentication Policies

(Passwords): Update the corporate password policy to mandate minimum complexity standards, requiring at least eight characters, a combination of letters, at least one number, and special characters. Concurrently, adopt and integrate a centralized password management system to technically enforce these requirements throughout the organization. 6. **(Risk 7) Vulnerabilities in Legacy Systems:** Establish and formalize a regular schedule for monitoring and maintenance tasks of end-of-life systems. It is necessary to clearly document the manual intervention methods required for the safe operation of this infrastructure.

LOW Priority (Medium-Term Implementation) 7. (Risk 5) Absence of Intrusion Detection:

Plan and budget for the acquisition and installation of an Intrusion Detection System (IDS). The implementation of this advanced monitoring tool should be executed once the high-priority preventive measures (encryption, access controls) and corrective measures (backups) have been fully stabilized.

Regulatory Compliance Status

The current compliance posture of Botium Toys presents critical deficiencies that expose the company to severe regulatory fines and reputational damage. The status against key reference frameworks is detailed below:

- **PCI DSS (Payment Card Industry Data Security Standard): Severe Non-Compliance.** The organization fails to protect customers' financial data, as the internal environment is not secure, lacks standardized access controls, and does not implement robust password management policies.
- **GDPR (General Data Protection Regulation): Partial / Deficient Compliance.** On a positive note, the company has established administrative response protocols, including privacy policies and a plan to notify E.U. customers within 72 hours in the event of a breach. However, it fundamentally fails in the technical protection and privacy of personal data (PII/SPII) and in the classification of its inventory.
- **SOC Type 1 and 2 (System and Organizations Controls): Partial Compliance.** The IT department has managed to ensure the operational availability of systems and has integrated controls that guarantee data integrity. Nevertheless, confidentiality principles and user access policies are completely absent.

Improvement Recommendations

To reduce the overall risk level (currently rated at 8/10) and align the organization with industry best practices, management is recommended to prioritize the following strategic actions:

1. **Execute an Asset Discovery and Classification Program:** Aligned with the "Identify" function of the NIST CSF framework, it is imperative to map what systems and data the company possesses in order to protect them and evaluate the real impact of their potential operational loss.
2. **Implement End-to-End Data Encryption:** To comply with PCI DSS and mitigate the impact of a potential infiltration, strong cryptography must be applied to all financial and personal information both at rest (local databases) and in transit.
3. **Deploy a Zero Trust Model and Identity Management:** Immediate global accesses must be revoked and the principle of least privilege applied, ensuring employees only access data strictly necessary for their role. This must be accompanied by a unified password manager.
4. **Design and Implement Business Continuity (BCP) and Disaster Recovery (DRP) Plans:** It is essential to establish routine, immutable, and off-site backups for critical data, as well as to document recovery steps in the event of a ransomware attack or physical disaster at the facilities.

Comunicacion Spa

Informe de Auditoría de Seguridad

Alcance General

El alcance de esta auditoría se define como la evaluación integral de todo el programa de seguridad de la empresa Botium Toys. El objetivo es revisar la postura de seguridad física y lógica de la organización para evaluar los controles existentes, clasificar los activos y determinar el nivel de adherencia a las mejores prácticas de cumplimiento.

1. Infraestructura y Activos Físicos (In-Scope)

- **Equipos de empleados:** Dispositivos gestionados por el departamento de TI, incluyendo computadoras de escritorio, computadoras portátiles, teléfonos inteligentes, estaciones de trabajo remotas y componentes periféricos.
- **Seguridad perimetral y física:** Instalaciones de la ubicación principal, lo que comprende las oficinas centrales, la tienda minorista (*storefront*) y el almacén de productos adyacente. Esto incluye la evaluación de las cerraduras, el circuito cerrado de televisión (CCTV) y los sistemas de detección y prevención de incendios.

2. Redes y Sistemas Tecnológicos (In-Scope)

- **Infraestructura de red:** Evaluación de la red interna, el acceso a internet, las reglas del firewall y las metodologías de retención y almacenamiento de datos.
- **Servicios y Aplicaciones:** Auditoría de los sistemas de contabilidad, telecomunicaciones, bases de datos, seguridad, plataformas de comercio electrónico y gestión de inventario.
- **Sistemas Heredados (*Legacy*):** Revisión de los sistemas al final de su vida útil (*end-of-life*) y sus protocolos de monitoreo y mantenimiento manual.

3. Procesos y Cumplimiento Normativo (In-Scope)

- **Controles de Seguridad:** Análisis de las políticas de contraseñas, gestión de identidades, principios de menor privilegio, separación de funciones, software antivirus, planes de recuperación ante desastres y copias de seguridad.
- **Marcos Regulatorios:** Evaluación del cumplimiento de los estándares PCI DSS (para la protección de datos de tarjetas de crédito), GDPR (para la privacidad de los clientes de la U.E.) y los principios de los controles SOC tipo 1 y 2.

Fuera de Alcance (Out-of-Scope)

- Auditorías de seguridad a proveedores externos, servicios en la nube de terceros o pasarelas de pago externas no gestionadas directamente por Botium Toys.

- Pruebas de ingeniería social (como campañas de *phishing* simuladas) dirigidas a los empleados.

Riesgos Detectados

1. **Políticas de Autenticación Deficientes (Contraseñas Débiles):** Aunque existe una política de contraseñas, sus requisitos son nominales y no exigen una complejidad mínima adecuada (como la combinación de letras, números y caracteres especiales). Además, la ausencia de un sistema centralizado de gestión de contraseñas aumenta significativamente el riesgo de accesos no autorizados mediante ataques de fuerza bruta o robo de credenciales.
2. **Ausencia de Controles de Acceso y Segregación de Funciones:** Actualmente, no se aplican los principios de menor privilegio ni la separación de tareas. Esto significa que todos los empleados poseen un acceso irrestricto a los datos almacenados internamente, incluyendo información personal (PII/SPII) y datos de tarjetas de crédito de los clientes. Esta falta de delimitación técnica anula la trazabilidad interna; en caso de producirse una brecha de seguridad o robo de información, el equipo de TI será incapaz de realizar un análisis forense efectivo para determinar el origen de la fuga o identificar el usuario comprometido.
3. **Falta de Encriptación de Datos Sensibles:** La empresa no está utilizando protocolos de cifrado para proteger la confidencialidad de la información financiera de los clientes durante su aceptación, procesamiento, transmisión o almacenamiento local en las bases de datos. Este es un fallo crítico: si un actor malintencionado logra evadir las defensas perimetrales e ingresar al sistema, podrá extraer a placer la totalidad de los datos en texto plano. Esto no solo garantiza la exposición total de la información, sino que asegura el incumplimiento de múltiples normativas internacionales (como GDPR y PCI DSS).
4. **Inexistencia de Copias de Seguridad y Planes de Recuperación (Riesgo Crítico de Disponibilidad):**
La organización es extremadamente vulnerable a la pérdida definitiva de información, ataques de *ransomware* o interrupciones operativas. Al no contar con respaldos de los datos críticos ni protocolos de actuación ante desastres, un incidente mayor podría paralizar o destruir el negocio por completo.
5. **Ausencia de Detección de Intrusos (Ceguera Operativa):** Aunque la red perimetral cuenta con un *firewall*, la empresa carece de herramientas para detectar amenazas que logren evadir esta primera barrera. Sin un IDS, la empresa no tiene forma de saber si un atacante ya está dentro de la red filtrando datos o moviéndose lateralmente.
6. **Gestión Inadecuada y Desconocimiento del Inventario de Activos:** En ciberseguridad, no se puede proteger lo que no se conoce. El departamento de TI no tiene un inventario claro ni clasificado de los sistemas, lo que imposibilita una correcta gestión de vulnerabilidades, evaluación del impacto y respuesta efectiva a incidentes.
7. **Vulnerabilidades en Sistemas Heredados (Legacy Systems):** Los sistemas al final de su vida útil (*end-of-life*) representan un riesgo significativo ya que suelen carecer de

parches de seguridad modernos. En Botium Toys, la falta de procedimientos claros y calendarios regulares para el mantenimiento de estos sistemas aumenta exponencialmente la probabilidad de que sean utilizados como vector de entrada por atacantes.

Plan de Urgencia de Mitigación

Prioridad ALTA (Crítica e Inmediata)

1. **(Riesgo 6) Gestión Inadecuada e Inventario de Activos:** Implementar un proceso exhaustivo para identificar y clasificar todos los activos físicos y lógicos de la empresa, alineándose con la función "Identificar" del marco NIST CSF. Esta acción es un paso fundamental para determinar qué activos están en riesgo y evaluar el impacto en la continuidad del negocio en caso de pérdida.
2. **(Riesgo 2) Controles de Acceso y Segregación de Funciones:** Implementar de inmediato el principio de menor privilegio (Least Privilege) y la separación de tareas (Separation of duties). Se debe restringir el acceso a la red interna para que solo los usuarios estrictamente autorizados puedan visualizar y operar la información almacenada, protegiendo así los datos de los titulares de tarjetas (PCI DSS) y la PII/SPII de los clientes (GDPR).
3. **(Riesgo 3) Encriptación de Datos Sensibles:** Desplegar protocolos de cifrado robustos para asegurar la confidencialidad de la información financiera de los clientes y otros datos confidenciales. El cifrado debe aplicarse ineludiblemente en todos los puntos donde la información sea aceptada, procesada, transmitida y almacenada localmente en la base de datos interna de la compañía.
4. **(Riesgo 4) Copias de Seguridad y Planes de Recuperación:** Desarrollar, documentar y probar un Plan de Recuperación ante Desastres (Disaster recovery plans). A la par, se debe implementar inmediatamente un sistema de copias de seguridad (Backups) regulares y aisladas para todos los datos críticos del negocio, garantizando la disponibilidad ante incidentes.

Prioridad MEDIA (Implementación a Corto Plazo)

5. **Riesgo 1) Políticas de autenticación (Contraseñas):** Actualizar la política de contraseñas corporativa para exigir estándares de complejidad mínima, requiriendo al menos ocho caracteres, una combinación de letras, al menos un número y caracteres especiales. Simultáneamente, adoptar e integrar un sistema de gestión de contraseñas centralizado para hacer cumplir de manera técnica estos requisitos en toda la organización.
6. **(Riesgo 7) Vulnerabilidades en Sistemas Heredados (Legacy Systems):** Establecer y formalizar un cronograma regular para las tareas de monitoreo y mantenimiento de los sistemas al final de su vida útil (end-of-life). Es necesario documentar de forma clara los

métodos de intervención manual requeridos para la operación segura de esta infraestructura.

Prioridad BAJA (Implementación a Mediano Plazo)

7. **(Riesgo 5) Ausencia de Detección de Intrusos: Planificar y presupuestar la adquisición e instalación de un Sistema de Detección de Intrusiones (IDS).** La implementación de esta herramienta de monitoreo avanzado debe ejecutarse una vez que las medidas preventivas (encriptación, controles de acceso) y correctivas (backups) de prioridad alta hayan sido completamente estabilizadas.

Estado de Cumplimiento Normativo

La postura de cumplimiento actual de Botium Toys presenta deficiencias críticas que exponen a la empresa a severas multas regulatorias y daños reputacionales. A continuación, se detalla el estado frente a los principales marcos de referencia:

- **PCI DSS (Payment Card Industry Data Security Standard):** Incumplimiento Severo. La organización falla en proteger los datos financieros de los clientes, ya que el entorno interno no es seguro, carece de controles de acceso estandarizados y no implementa políticas de gestión de contraseñas robustas.
- **GDPR (General Data Protection Regulation):** Cumplimiento Parcial / Deficiente. Como aspecto positivo, la empresa tiene establecidos protocolos de respuesta administrativa, incluyendo políticas de privacidad y un plan para notificar a los clientes de la U.E. en un plazo de 72 horas ante una brecha. Sin embargo, incumple fundamentalmente en la protección técnica y privacidad de los datos personales (PII/SPII) y en la clasificación de su inventario.
- **SOC Tipo 1 y 2 (System and Organizations Controls):** Cumplimiento Parcial. El departamento de TI ha logrado asegurar la disponibilidad operativa de los sistemas y ha integrado controles que garantizan la integridad de los datos. No obstante, los principios de confidencialidad y las políticas de acceso de usuarios están completamente ausentes.

Recomendaciones de Mejora

Para reducir el nivel de riesgo general (actualmente calificado con un 8/10) y alinear a la organización con las mejores prácticas de la industria, se recomienda a la gerencia priorizar las siguientes acciones estratégicas:

1. **Ejecutar un Programa de Descubrimiento y Clasificación de Activos:** Alineado con la función "Identificar" (*Identify*) del marco NIST CSF, es imperativo mapear qué sistemas y datos posee la empresa para poder protegerlos y evaluar el impacto real de su posible pérdida operativa.

2. Implementar Cifrado de Datos de Extremo a Extremo: Para cumplir con PCI DSS y mitigar el impacto de una posible infiltración, se debe aplicar criptografía fuerte a toda la información financiera y personal tanto en reposo (bases de datos locales) como en tránsito.

3. Desplegar un Modelo de Confianza Cero (Zero Trust) y Gestión de Identidades: Se deben revocar los accesos globales inmediatos y aplicar el principio de menor privilegio, asegurando que los empleados solo accedan a los datos estrictamente necesarios para su rol. Esto debe acompañarse de un gestor de contraseñas unificado.

4. Diseñar e Implementar Planes de Continuidad (BCP) y Recuperación (DRP): Es fundamental establecer rutinas de copias de seguridad inmutables y externas para los datos críticos, así como documentar los pasos de recuperación ante un ataque de *ransomware* o un desastre físico en las instalaciones.